

DLMM 0.11.0

Smart Contract Security Assessment

December 2025

Prepared for:

Meteora

Prepared by:

Offside Labs

Ronny Xing

Sirius Xie





Contents

1	About Offside Labs	2
2	Executive Summary	3
3	Summary of Findings	7
4	Key Findings and Recommendations	8
4.1	Transfer Hook Authority Whitelist Can be Bybassed	8
4.2	Invalid Creator Configuration	8
4.3	Informational and Undetermined Issues	9
5	Disclaimer	10



1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



https://twitter.com/offside_labs



2 Executive Summary

Introduction

Offside Labs completed a security audit of *DLMM* smart contracts, starting on December 11, 2025, and concluding on December 13, 2025.

Project Overview

Meteora's Dynamic Liquidity Market Maker (DLMM) gives LPs access to dynamic fees and precise liquidity concentration all in real-time. DLMM is designed with features that provide more flexibility for LPs and help LPs earn as much fees as possible with their capital.

DLMM organizes the liquidity of an asset pair into discrete price bins. Token reserves deposited in a liquidity bin are made available for exchange at the price defined for that particular bin. Swaps that happen within the price bin itself would not suffer from slippage. The market for the asset pair is established by aggregating all the discrete liquidity bins.

This update upgrades positions by adding support for dynamic positions and rebalance operations, allowing users to adjust their positions more flexibly. DLMM also adds support for permissionless Token-2022 mints with the Transfer Hook extension.

Audit Scope

The assessment scope contains mainly the smart contracts of the lb-clmm program for the *DLMM* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- *DLMM*
 - Codebase: [PR-443](#)
 - Commit Hash: 1e8b4a29a46a38b99dfce9ca53d489c4734bcb90

We confirm that all issues have been resolved in the following commit:

- *DLMM*
 - Commit Hash: ae3aeb9a97179cadab11c7bf14ca75b431a27384

We listed the files we have audited below:

- *DLMM*
 - programs/lb_clmm/src/constants.rs
 - programs/lb_clmm/src/errors.rs
 - programs/lb_clmm/src/instructions/admin/close_claim_fee_operator_account.rs
 - programs/lb_clmm/src/instructions/admin/close_claim_protocol_fee_operator.rs
 - programs/lb_clmm/src/instructions/admin/close_operator_account.rs
 - programs/lb_clmm/src/instructions/admin/create_claim_protocol_fee_operator.rs
 - programs/lb_clmm/src/instructions/admin/create_operator_account.rs



- `programs/lb_clmm/src/instructions/admin/initialize_preset_parameters.rs`
- `programs/lb_clmm/src/instructions/admin/mod.rs`
- `programs/lb_clmm/src/instructions/claim_fee.rs`
- `programs/lb_clmm/src/instructions/claim_reward.rs`
- `programs/lb_clmm/src/instructions/deposit/add_liquidity.rs`
- `programs/lb_clmm/src/instructions/deposit/add_liquidity_by_strategy.rs`
- `programs/lb_clmm/src/instructions/deposit/add_liquidity_by_strategy_one_side.rs`
- `programs/lb_clmm/src/instructions/deposit/add_liquidity_by_weight.rs`
- `programs/lb_clmm/src/instructions/deposit/add_liquidity_by_weight_one_side.rs`
- `programs/lb_clmm/src/instructions/initialize_pool/initialize_customizable_permissionless_lb_pair.rs`
- `programs/lb_clmm/src/instructions/initialize_pool/initialize_permission_lb_pair.rs`
- `programs/lb_clmm/src/instructions/initialize_pool/initialize_permissionless_lb_pair.rs`
- `programs/lb_clmm/src/instructions/mod.rs`
- `programs/lb_clmm/src/instructions/operator/close_preset_parameter.rs`
- `programs/lb_clmm/src/instructions/operator/close_preset_parameter2.rs`
- `programs/lb_clmm/src/instructions/operator/close_token_badge.rs`
- `programs/lb_clmm/src/instructions/operator/fund_reward.rs`
- `programs/lb_clmm/src/instructions/operator/initialize_preset_parameters.rs`
- `programs/lb_clmm/src/instructions/operator/initialize_reward.rs`
- `programs/lb_clmm/src/instructions/operator/initialize_token_badge.rs`
- `programs/lb_clmm/src/instructions/operator/mod.rs`
- `programs/lb_clmm/src/instructions/operator/set_activation_point.rs`
- `programs/lb_clmm/src/instructions/operator/set_pair_status.rs`
- `programs/lb_clmm/src/instructions/operator/set_pre_activation_duration.rs`
- `programs/lb_clmm/src/instructions/operator/set_pre_activation_swap_address.rs`
- `programs/lb_clmm/src/instructions/operator/update_fee_parameters.rs`
- `programs/lb_clmm/src/instructions/operator/update_reward_duration.rs`
- `programs/lb_clmm/src/instructions/operator/update_reward_funder.rs`
- `programs/lb_clmm/src/instructions/operator/withdraw_ineligible_reward.rs`
- `programs/lb_clmm/src/instructions/operator/withdraw_protocol_fee.rs`
- `programs/lb_clmm/src/instructions/operator/zap_protocol_fee/damm_v2_zap.rs`
- `programs/lb_clmm/src/instructions/operator/zap_protocol_fee/dlmm_zap.rs`
- `programs/lb_clmm/src/instructions/operator/zap_protocol_fee/jup_v6_zap.rs`
- `programs/lb_clmm/src/instructions/operator/zap_protocol_fee/mod.rs`
- `programs/lb_clmm/src/instructions/operator/zap_protocol_fee/process_zap_protocol_fee.rs`
- `programs/lb_clmm/src/instructions/permissionless_operations/initialize_bin_array.rs`
- `programs/lb_clmm/src/instructions/permissionless_operations/initialize_bin_array_bitmap_extension.rs`
- `programs/lb_clmm/src/instructions/permissionless_operations/migrate_bin_ar-`



- ray.rs
- programs/lb_clmm/src/instructions/permissionless_operations/mod.rs
 - programs/lb_clmm/src/instructions/position/close_position.rs
 - programs/lb_clmm/src/instructions/position/initialize_position.rs
 - programs/lb_clmm/src/instructions/position/initialize_position_pda.rs
 - programs/lb_clmm/src/instructions/position/migrate_position.rs
 - programs/lb_clmm/src/instructions/position_authorize.rs
 - programs/lb_clmm/src/instructions/rebalance/process_add_liquidity.rs
 - programs/lb_clmm/src/instructions/rebalance/process_claim_fee_and_rewards.rs
 - programs/lb_clmm/src/instructions/rebalance/process_remove_liquidity.rs
 - programs/lb_clmm/src/instructions/rebalance/process_resize_position.rs
 - programs/lb_clmm/src/instructions/rebalance/rebalance_params.rs
 - programs/lb_clmm/src/instructions/rebalance/rebalance_wrapper.rs
 - programs/lb_clmm/src/instructions/reset_tombstone_fields/mod.rs
 - programs/lb_clmm/src/instructions/reset_tombstone_fields/reset_bin_array_tombstone_fields.rs
 - programs/lb_clmm/src/instructions/reset_tombstone_fields/reset_pool_tombstone_fields.rs
 - programs/lb_clmm/src/instructions/reset_tombstone_fields/reset_position_tombstone_fields.rs
 - programs/lb_clmm/src/instructions/set_pair_status_permissionless.rs
 - programs/lb_clmm/src/instructions/swap.rs
 - programs/lb_clmm/src/instructions/update_fees_and_rewards.rs
 - programs/lb_clmm/src/instructions/v2/add_liquidity2.rs
 - programs/lb_clmm/src/instructions/v2/add_liquidity_by_strategy2.rs
 - programs/lb_clmm/src/instructions/v2/add_liquidity_single_side_precise2.rs
 - programs/lb_clmm/src/instructions/v2/claim_fee2.rs
 - programs/lb_clmm/src/instructions/v2/claim_reward2.rs
 - programs/lb_clmm/src/instructions/v2/initialize_customizable_permissionless_lb_pair2.rs
 - programs/lb_clmm/src/instructions/v2/mod.rs
 - programs/lb_clmm/src/instructions/v2/remove_liquidity2.rs
 - programs/lb_clmm/src/instructions/v2/swap2.rs
 - programs/lb_clmm/src/instructions/v2/update_fees_and_reward2.rs
 - programs/lb_clmm/src/instructions/withdraw/remove_all_liquidity.rs
 - programs/lb_clmm/src/instructions/withdraw/remove_liquidity.rs
 - programs/lb_clmm/src/lb_access_control.rs
 - programs/lb_clmm/src/lib.rs
 - programs/lb_clmm/src/manager/bin_array_manager.rs
 - programs/lb_clmm/src/manager/mod.rs
 - programs/lb_clmm/src/math/safe_math.rs
 - programs/lb_clmm/src/math/weight_to_amounts.rs
 - programs/lb_clmm/src/state/bin.rs
 - programs/lb_clmm/src/state/bin_array_bitmap_extension.rs
 - programs/lb_clmm/src/state/dynamic_position.rs



- programs/lb_clmm/src/state/lb_pair.rs
- programs/lb_clmm/src/state/mod.rs
- programs/lb_clmm/src/state/operator.rs
- programs/lb_clmm/src/state/oracle.rs
- programs/lb_clmm/src/state/parameters.rs
- programs/lb_clmm/src/state/position.rs
- programs/lb_clmm/src/state/preset_parameters.rs
- programs/lb_clmm/src/state/preset_parameters2.rs
- programs/lb_clmm/src/utls/seeds.rs
- programs/lb_clmm/src/utls/token.rs
- programs/lb_clmm/src/utls/token2022.rs

Findings

The security audit revealed:

- 1 critical issue
- 0 high issue
- 0 medium issue
- 1 low issue
- 1 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



3 Summary of Findings

ID	Title	Severity	Status
01	Transfer Hook Authority Whitelist Can be Bypassed	Critical	Fixed
02	Invalid Creator Configuration	Low	Fixed
03	JUP_V6 amount_in Parameter Manipulation	Informational	Fixed



4 Key Findings and Recommendations

4.1 Transfer Hook Authority Whitelist Can be Bybassed

Severity: Critical

Status: Fixed

Target: Smart Contract

Category: Token2022

Description

A new type of token 2022 whitelist named `TokenExtensionType::TransferHook` is added for transfer hook extension authority.

However this whitelist check for `transfer_hook.authority` can be bybassed. An attacker can initialize a token-2022 mint with transfer hook extension and set a malicious hook program id. Then the attacker can transfer the transfer hook authority to an authority which has a valid `TokenExtensionType::TransferHook` `TokenBadge`. Since the hook program ID is not cleared during hook authority transfers.

Impact

After transferring the hook authority to an authority of a valid `TokenBadge`, the attacker can use this token-2022 mint with a malicious hook program to initialize a pool.

Recommendation

Implementing hook program ID enforcement in `TokenBadge`. But it would constitute a breaking change.

Mitigation Review Log

Fixed in commit `689ac8c354706c7e24ec1a2ce63c56c888e2b7ee`

4.2 Invalid Creator Configuration

Severity: Low

Status: Fixed

Target: Smart Contract

Category: Logic Error

Description

Instruction `initialize_permission_lb_pair` uses `payer` as `lb_pair.creator`.



```
165 let keys = InitializePairKeys {
166     reserve_x: ctx.accounts.reserve_x.key(),
167     reserve_y: ctx.accounts.reserve_y.key(),
168     token_mint_x: ctx.accounts.token_mint_x.key(),
169     token_mint_y: ctx.accounts.token_mint_y.key(),
170     base: ctx.accounts.base.key(),
171     creator: ctx.accounts.payer.key(),
172 };
```

[programs/lb_clmm/src/instructions/initialize_pool/initialize_permission_lb_pair.rs#L165-L172](#)

When using a multisig wallet, the payer (i.e., executor) can potentially be any account.

Recommendation

It's better to use the `signer` account, aka operator, as the `lb_pair` creator.

Mitigation Review Log

Fixed in commit `8b281b7b4744dbe4f29a4efc459d3b1d9ffecd48`

4.3 Informational and Undetermined Issues

JUP_V6 amount_in Parameter Manipulation

Severity: Informational

Status: Fixed

Target: Smart Contract

Category: Logic Error

The parser function `extract_amm_accounts_and_info` extracts the `amount_in_offset` for the JUP_V6 interface from the end of `zap_params.payload_data` :

- [programs/lb_clmm/src/instructions/operator/zap_protocol_fee.rs#L341-L346](#)
- [programs/lb_clmm/src/instructions/operator/zap_protocol_fee.rs#L353-L358](#)

The operator can append padding data to the end of `zap_params.payload_data` to place arbitrary `amount_in` parameters at the specified `amount_in_offset` position.

A malicious operator could exploit this to bypass token input into JUP v6 swaps, thereby stealing(not transferring) protocol fees.

Fixed in commit `4d9ddb6069d40a712df5e389a90bbcb50bb41d82`.



5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

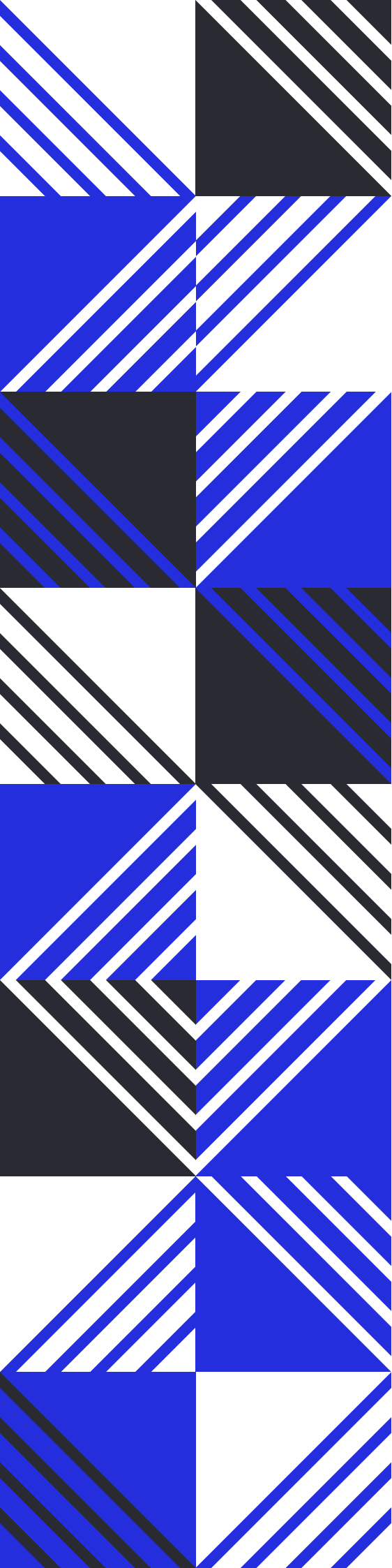
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 https://twitter.com/offside_labs